Bertindaklah sebagai Senior Full-Stack Developer, Security Engineer, dan SEO Specialist.

Saya akan meluncurkan sebuah aplikasi/web baru. Lakukan audit menyeluruh (Pre-Launch Audit) terhadap kode, arsitektur, atau deskripsi proyek yang saya berikan.

Periksa proyek saya berdasarkan 60 poin checklist di bawah ini. Untuk setiap poin, berikan status (Aman / Berisiko / Tidak Ada), tingkat keparahan (Kritis / Tinggi / Sedang / Rendah), dan rekomendasi perbaikan yang spesifik beserta contoh kodenya (jika relevan).

[KODE/DESKRIPSI PROYEK SAYA]:

(Tempel kode, struktur folder, atau penjelasan tech stack Anda di sini)

AUDIT CHECKLIST:

BAGIAN 1: KEAMANAN APLIKASI & BACKEND (Security Check)

1. API key aman & tidak terekspos di frontend.
2. File .env tidak dipublikasikan (masuk ke .gitignore).
3. Tidak ada hardcode secret di dalam kode.
4. Cek kebocoran secret di riwayat Git.
5. Debug mode dalam keadaan OFF (Production mode).
6. Penanganan error tidak membocorkan stack trace atau info sensitif.
7. Validasi input di semua endpoint.
8. Sanitasi input untuk mencegah malicious payload.
9. Proteksi terhadap SQL Injection.
10. Proteksi terhadap XSS (Cross-Site Scripting).
11. Autentikasi dilakukan di sisi server (Server-side auth).

12. Pengecekan akses user (Otorisasi) berjalan dengan benar.

13. Role admin diamankan dengan ketat.

14. Database tidak terekspos ke publik.

15. DB permission ketat (prinsip least privilege).

16. Password di-hash dengan algoritma kuat (bcrypt/argon2).

17. Manajemen session aman (HttpOnly, Secure, SameSite).

18. Alur reset password aman (token kadaluarsa, rate limit).

19. Batasi ukuran dan tipe file upload.

20. Scan file yang di-upload (Antivirus/Malware scan).

BAGIAN 2: KEAMANAN API & LOGIKA BISNIS (Security Check Part 2)

1. Rate limit API untuk mencegah brute force/DDoS.

2. Konfigurasi CORS ketat (hanya domain terpercaya).

3. Proteksi CSRF (Cross-Site Request Forgery).

4. Cegah SSRF (Server-Side Request Forgery).

5. Cegah Path Traversal.

6. Validasi input API (schema validation).

7. Validasi output API (jangan kirim data berlebih).

8. Rute admin diamankan (tidak bisa diakses user biasa).

9. Ganti semua default password/kredensial.

10. Audit semua endpoint (pastikan tidak ada endpoint yang terbuka).

11. Verifikasi webhook (signature validation).

12. Cek integrasi payment server (sandbox vs production).

13. Proteksi harga anti-tamper (validasi harga di backend).

14. Cek IDOR (Insecure Direct Object Reference).

15. Log jangan bocor (jangan catat password/token di log).

16. Private source map tidak dipublikasikan.

17. Update dependensi (npm/composer) ke versi terbaru yang aman.

18. Tes restore backup database.

19. Pasang Security Headers (CSP, HSTS, X-Frame-Options).

20. Tes security live (penetration testing dasar).

BAGIAN 3: KUALITAS WEBSITE & UX (Wajib Dicek via AI/ChatGPT)

1. CTA (Call to Action) jelas.

2. Tombol WhatsApp (WA) berfungsi.

3. Sticky CTA di mobile.

4. Form inquiry berfungsi dengan baik.

5. Halaman Thank-you page setelah submit.

6. Fix kontras warna (aksesibilitas).

7. Halaman Portfolio/Produk rapi.

8. Testimoni asli (bukan fake).

9. Custom 404 page.

10. Halaman FAQ.

11. Privacy Policy.

12. HTTPS aktif di semua halaman.

13. Mobile friendly (responsif).

14. Kompresi gambar (WebP/AVIF).

15. Judul halaman unik (Title Tag).

16. Meta description menarik.

17. Social preview (Open Graph) berfungsi.

18. Alt text pada semua gambar.

19. Google Maps terintegrasi (jika perlu).

20. GA4 & Tracking WA/CTA terpasang.

BAGIAN 4: SEO TEKNIS & TESTING (Wajib Dicek via AI/ChatGPT Part 2)

1. Sitemap.xml tersedia.

2. Robots.txt dikonfigurasi dengan benar.

3. Google Search Console terhubung.

4. Submit sitemap ke Search Console.

5. Internal links berjalan baik.

6. Breadcrumbs terpasang.

7. Canonical URL untuk mencegah duplicate content.

8. Local schema markup.

9. Org schema markup.

10. Cek indexing (pastikan halaman penting terindeks).

11. Cek broken links (404).

12. Validasi form (client & server side).

13. Anti-spam form (reCAPTCHA/Honeypot).

14. Track form submit di analytics.

15. Track klik WA di analytics.

16. Track klik CTA di analytics.

17. Pasang favicon.

18. Custom 404 page (pastikan SEO friendly).

19. Backup website berjalan otomatis.

20. Test all device (iOS, Android, Desktop, Tablet).

FORMAT OUTPUT YANG DIINGINKAN:

Berikan hasil audit dalam bentuk tabel dengan kolom:

No | Kategori | Item Checklist | Status | Tingkat Risiko | Rekomendasi Perbaikan.

Di akhir laporan, berikan "Top 3 Prioritas Utama" yang harus segera saya perbaiki sebelum launch.